DOCUMENT

02

# Requirements Specification

Rules, decisions, boundaries and traceability

Source of truth: `specs/001-invoice-approval-limits/spec.md` (full text in document 12). This document restates it as a reference with a decision table and traceability to tests.

## 1. Scope

In scope: who may approve an invoice of a given amount, how many approvals it needs, what a refusal looks like, and that a refusal has no side effects.

Out of scope: user management, notifications to approvers, a real database, session expiry (deferred, see document 11).

## 2. Glossary

| Term | Meaning |
|---|---|
| Approver | The signed-in user (username and role) who is trying to approve |
| Approval record | One accepted approval: username, role, UTC time, stored on the invoice |
| Required approvals | 1, or 2 when the amount is above 500,000.00 |
| Refused attempt | An approval the rules do not allow. This is **not** the explicit Reject action, which is unchanged |

## 3. Clarified decisions

| Question | Decision |
|---|---|
| Are limits inclusive? | Yes. 50,000.00 is allowed for a Manager, 50,000.01 is not. 500,000.00 needs one Director, 500,000.01 needs two approvers |
| Who gives the first approval above 500,000? | A Manager or a Director |
| What is "the same user"? | Same username after `strip().casefold()` |
| Same Manager approves twice, which message wins? | The duplicate-user message (more specific) |
| Legacy `Approver` role | Replaced by `Manager`. `Admin` can reject and delete but never approve |
| Does a refused attempt undo an earlier accepted first approval? | No. Refusals write nothing; the first approval stays recorded |

## 4. Functional requirements

| ID | Requirement |
|---|---|
| FR-001 | A Manager MUST be able to approve an invoice up to and including 50,000.00 |
| FR-002 | A Director MUST be able to approve an invoice up to and including 500,000.00 |
| FR-003 | An invoice above 500,000.00 MUST need two approvals from two distinct users; it stays Pending Approval after the first and becomes Approved after the second |
| FR-004 | The second approver above 500,000.00 MUST be a Director; the first MAY be a Manager or a Director |
| FR-005 | The same user MUST NOT count as both approvers (trimmed, case-insensitive) |
| FR-006 | Roles other than Manager and Director MUST NOT approve any invoice |
| FR-007 | A refused approval MUST return a specific reason (HTTP 403, `{"error": "..."}`) and leave status, decider, decision time and approvals unchanged |
| FR-008 | Each accepted approval MUST be recorded with username, role and a UTC timestamp |
| FR-009 | Existing behaviour (submit, reject with required reason, 404/409/400 mapping, Admin-only delete) MUST keep working |
| FR-010 | The UI MUST show the refusal reason and, for invoices needing two approvals, how many are recorded |

## 5. Decision table

Rows are evaluated top to bottom; the first match decides.

| # | Condition | Outcome |
|---|---|---|
| 1 | Role is not Manager or Director | Refused: "Role X is not allowed to approve invoices." |
| 2 | Amount <= 50,000.00 | Allowed (one approval completes the invoice) |
| 3 | Amount <= 500,000.00 and role is Director | Allowed (one approval completes the invoice) |
| 4 | Amount <= 500,000.00 and role is Manager | Refused: Manager limit message |
| 5 | Amount > 500,000.00 and this user already approved | Refused: duplicate-user message |
| 6 | Amount > 500,000.00, an approval exists, and role is not Director | Refused: second approver must be a Director |
| 7 | Amount > 500,000.00 otherwise | Allowed (first approval keeps Pending; second completes) |

State checks run before this table: an invoice that is not Pending Approval is refused with 409 and nothing changes.

## 6. Boundary values

| Amount | Manager | Director | Approvals needed |
|---|---|---|---|
| 50,000.00 | allowed | allowed | 1 |
| 50,000.01 | refused | allowed | 1 |
| 500,000.00 | refused | allowed | 1 |
| 500,000.01 | first approval only | first or second approval | 2 |

## 7. Acceptance scenarios (summary)

| Story | Given / When / Then |
|---|---|
| US1 | Pending 50,000.00, Manager approves, then Approved with the Manager as decider |
| US1 | Pending 50,000.01, Manager approves, then refused with the 50,000.00 Manager limit reason; invoice unchanged |
| US1 | Pending 500,000.00, Director approves, then Approved |
| US1 | Any invoice, Admin approves, then refused with a reason; nothing changes |
| US2 | Pending 500,000.01, Director approves, then still Pending with exactly one approval and no decider |
| US2 | One approval by X, X approves again (any case/spacing), then refused; still exactly one approval |
| US2 | One approval, a Manager gives the second, then refused: second approver must be a Director |
| US2 | One approval, a different Director approves, then Approved with both recorded |
| US3 | Signed-in Manager clicks Approve on the 75,000.00 invoice, then the alert shows the reason and the invoice stays pending |

## 8. Traceability: requirement to tests

| Requirement | Where it is tested |
|---|---|
| FR-001, FR-002 | `test_approval_policy.py` (limit tests), `test_approval_service.py` (exactly at the limit), `test_api.py` (HTTP happy paths) |
| FR-003, FR-004 | policy and service tests for first/second approver; `test_two_directors_are_needed_above_the_director_limit` (API) |
| FR-005 | `test_same_user_cannot_be_both_approvers`, case/whitespace variants on the new and stored side (policy and service), API double-approval tests |

| Requirement | Where it is tested |
|---|---|
| FR-006 | `test_roles_other_than_manager_and_director_may_not_approve_anything`, Admin refusal tests at service and API level |
| FR-007 | `assert_refused_and_unchanged` helper in service tests, plus API tests comparing the full invoice before and after |
| FR-008 | `test_each_approval_records_when_it_happened_in_utc`, persistence tests |
| FR-009 | submit/reject/state-error tests and `test_api.py` status mapping tests |
| FR-010 | Playwright test `over-limit-rejection.spec.ts` and the `requiredApprovals` / `approvals` fields tested at API level |

## 9. Success criteria

| ID | Criterion | Result |
|---|---|---|
| SC-001 | Every rule has a positive test; each "MUST NOT" rule has a negative test asserting reason and unchanged invoice | Met |
| SC-002 | All four boundaries covered on both sides | Met |
| SC-003 | Mutation score at least 90%, every survivor explained | Met: 100% (132 of 132) |
| SC-004 | One Playwright test shows a refused over-limit approval | Met |